

RELATÓRIO DE DIAGNÓSTICO DE SEGURANÇA — REACT NATIVE

Aplicação: FUTAPP — Sistema de Reservas de Ginásios

Versão: React Native 0.81.5 / Expo SDK 54.0.x

Data: 11/06/2026

Auditor: Auditoria automatizada + revisão técnica de segurança

Escopo: OWASP Mobile Top 10 — M1 a M10

SUMÁRIO EXECUTIVO

Crítico: 7

Alto: 7

Médio: 4

Baixo: 1

Total: 19

Score geral de risco:

[X] Crítico [] Alto [] Médio [] Baixo

A aplicação apresenta risco geral **crítico**, principalmente por ausência de autenticação real no servidor, senhas armazenadas em texto plano, comunicação HTTP sem TLS, ausência de armazenamento seguro, exposição de dados pessoais e financeiros, uso de `json-server` como backend sem proteção, ausência de validação de entrada e falta de controles mínimos de privacidade, criptografia e hardening mobile.

ACHADOS

ID: VULN-M1-001

Categoria OWASP: M1 — Improper Credential Usage

Severidade: Crítica

CWE: CWE-256 / CWE-312 / CWE-916

Componente afetado: `json-server/db.json`, `src/apiService/api.ts`, `src/types/usuario.ts`

Causa raiz:

As senhas dos usuários estão armazenadas em texto plano no banco `db.json`, retornadas pela API e comparadas diretamente no lado do cliente. Não há hashing com bcrypt, Argon2 ou qualquer mecanismo seguro de autenticação.

Evidência:

`json-server/db.json` contém usuários com campo `"senha": "123"` e `"senha": "12345678"`.
`src/apiService/api.ts` realiza autenticação com `item.senha === senha`.

Impacto CIA:

C: ☒ Alto ☐ Médio ☐ Baixo

I: ☒ Alto ☐ Médio ☐ Baixo

A: ☐ Alto ☒ Médio ☐ Baixo

Vetor de ataque:

Um atacante que acesse o endpoint `/usuarios`, o arquivo `db.json` ou intercepte a resposta da API pode obter senhas em texto plano e se autenticar como qualquer usuário.

Recomendação:

Substituir `json-server` por backend real com autenticação server-side. Armazenar apenas `senhaHash`, usando Argon2id ou bcrypt com fator de custo adequado. Nunca retornar senha ou hash ao app.

Prazo sugerido: Imediato — 1 a 2 dias

Responsável: Backend

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M1-002

Categoria OWASP: M1 — Improper Credential Usage

Severidade: Alta

CWE: CWE-798

Componente afetado: `tests/helpers/test-data.helper.ts`, testes E2E

Causa raiz:

Credenciais de teste estão hardcoded em arquivos versionados, incluindo e-mails e senhas fixas.

Evidência:

Arquivo `tests/helpers/test-data.helper.ts` contém usuários de teste com senha literal `"12345678"`.

Impacto CIA:

C: ☒ Alto ☐ Médio ☐ Baixo

I: ☐ Alto ☒ Médio ☐ Baixo

A: ☐ Alto ☐ Médio ☒ Baixo

Vetor de ataque:

Qualquer pessoa com acesso ao repositório pode obter credenciais de teste e, caso sejam reutilizadas em staging ou produção, acessar ambientes indevidamente.

Recomendação:

Mover credenciais para variáveis de ambiente ou secrets do CI/CD. Criar `.env.test` ignorado pelo Git e usar valores injetados no pipeline.

Prazo sugerido: Curto prazo — até 3 dias

Responsável: QA / DevOps

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M2-001

Categoria OWASP: M2 — Inadequate Supply Chain Security

Severidade: Crítica

CWE: CWE-1104 / CWE-937

Componente afetado: `package-lock.json`, dependências transitivas

Causa raiz:

O projeto possui dependências com vulnerabilidades conhecidas, incluindo pacote transitivo `shell-quote@1.8.3` com CVSS 9.8, além de vulnerabilidades em `@xmldom/xmldom`, `postcss`, `uuid` e `brace-expansion`.

Evidência:

`npm audit` identificou 17 vulnerabilidades: 1 crítica, 1 alta e múltiplas moderadas.

Pacote crítico: `shell-quote <= 1.8.3`.

Impacto CIA:

C: ☒ Alto ☐ Médio ☐ Baixo

I: ☒ Alto ☐ Médio ☐ Baixo

A: ☒ Alto ☐ Médio ☐ Baixo

Vetor de ataque:

Comprometimento da cadeia de build, execução de código em ambiente de desenvolvimento ou CI/CD e manipulação de dependências transitivas vulneráveis.

Recomendação:

Executar `npm audit fix`, atualizar dependências vulneráveis, avaliar upgrade do Expo para corrigir cadeias transitivas e adicionar auditoria de dependências no CI.

Prazo sugerido: Imediato — até 2 dias

Responsável: DevOps / Mobile

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M2-002

Categoria OWASP: M2 — Inadequate Supply Chain Security

Severidade: Alta

CWE: CWE-1357

Componente afetado: `package.json`

Causa raiz:

O pacote `json-server@1.0.0-beta.15` está declarado em `dependencies`, indicando uso como dependência de produção. Além disso, há uso amplo de versionamento frouxo com `^` e `~`.

Evidência:

`package.json` possui `"json-server": "^1.0.0-beta.15"` em dependências.

Impacto CIA:

C: ☐ Alto ☒ Médio ☐ Baixo

I: ☒ Alto ☐ Médio ☐ Baixo

A: ☐ Alto ☒ Médio ☐ Baixo

Vetor de ataque:

Uma dependência beta ou atualizações automáticas não revisadas podem introduzir falhas, mudanças incompatíveis ou código malicioso na cadeia de build.

Recomendação:

Mover `json-server` para `devDependencies`, remover o `^`, pinar versões críticas e usar `npm ci` em CI/CD.

Prazo sugerido: Curto prazo — até 1 semana

Responsável: Mobile / DevOps

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M3-001

Categoria OWASP: M3 — Insecure Authentication/Authorization

Severidade: Crítica

CWE: CWE-287 / CWE-306

Componente afetado: `src/apiService/api.ts`, `src/app/login.tsx`

Causa raiz:

A autenticação é feita no cliente. O app consulta `/usuarios?email=...`, recebe dados completos do usuário e compara a senha localmente.

Evidência:

`loginUser()` busca usuários por e-mail e executa `usuarios.find((item) => item.senha === senha)`.

Impacto CIA:

C: ☒ Alto ☐ Médio ☐ Baixo

I: ☒ Alto ☐ Médio ☐ Baixo

A: ☐ Alto ☒ Médio ☐ Baixo

Vetor de ataque:

Qualquer pessoa pode consultar diretamente a API e obter dados de usuários, incluindo senhas, sem passar por autenticação server-side.

Recomendação:

Criar endpoint `POST /auth/login`, validar senha no servidor com hash seguro e retornar apenas token JWT ou token opaco de sessão.

Prazo sugerido: Imediato — 1 a 2 dias

Responsável: Backend

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M3-002

Categoria OWASP: M3 — Insecure Authentication/Authorization

Severidade: Crítica

CWE: CWE-639 / CWE-862

Componente afetado: `login.tsx`, `home.tsx`, `ginasios.tsx`, `lista.tsx`, `detalhar.tsx`

Causa raiz:

A identidade do usuário é propagada por parâmetros de URL, como `usuarioId` e `usuarioNome`, e usada para decisões de autorização. Não há JWT, sessão centralizada, SecureStore ou validação server-side.

Evidência:

```
router.push({ pathname: "/home", params: { usuarioId: usuario.id, usuarioNome: usuario.nome } }).
```

Permissões como `ehDono` são calculadas comparando `reserva.usuarioId` com `usuarioId` vindo da rota.

Impacto CIA:

C: ☒ Alto ☐ Médio ☐ Baixo

I: ☒ Alto ☐ Médio ☐ Baixo

A: ☒ Alto ☐ Médio ☐ Baixo

Vetor de ataque:

Um atacante pode alterar o parâmetro `usuarioId` na URL/deep link e se passar por outro usuário, podendo visualizar, editar ou aprovar solicitações indevidamente.

Recomendação:

Implementar `AuthContext`, armazenar token em `expo-secure-store`, proteger rotas e validar autorização no servidor usando o usuário autenticado do token.

Prazo sugerido: Imediato — até 3 dias

Responsável: Mobile / Backend

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M3-003

Categoria OWASP: M3 — Insecure Authentication/Authorization

Severidade: Alta

CWE: CWE-613 / CWE-307

Componente afetado: `src/app/home.tsx`, backend atual `json-server`

Causa raiz:

Não há sessão real, expiração, renovação, invalidação no logout ou rate limiting para tentativas de login.

Evidência:

Botão de logout apenas executa navegação para `/login`.

Não há token, blacklist, expiração ou controle de tentativas.

Impacto CIA:

C: ☐ Alto ☒ Médio ☐ Baixo

I: ☒ Alto ☐ Médio ☐ Baixo

A: ☒ Alto ☐ Médio ☐ Baixo

Vetor de ataque:

Usuários podem voltar para telas autenticadas pelo histórico de navegação, e atacantes podem tentar múltiplas senhas sem bloqueio.

Recomendação:

Implementar logout que remova tokens do SecureStore, usar `router.replace`, expiração de token, refresh token e rate limiting no endpoint de login.

Prazo sugerido: Curto prazo — até 1 semana

Responsável: Mobile / Backend

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M4-001

Categoria OWASP: M4 — Insufficient Input/Output Validation

Severidade: Crítica

CWE: CWE-20 / CWE-915

Componente afetado: `src/app/lista.tsx`, `src/app/detalhar.tsx`

Causa raiz:

O app serializa um objeto completo de reserva em parâmetro de URL usando

`JSON.stringify(item)` e depois desserializa com `JSON.parse` sem validação de schema.

Evidência:

`lista.tsx` envia `reserva: JSON.stringify(item)`.

`detalhar.tsx` faz cast direto para `Reserva`.

Impacto CIA:

C: ☒ Alto ☐ Médio ☐ Baixo

I: ☒ Alto ☐ Médio ☐ Baixo

A: ☐ Alto ☒ Médio ☐ Baixo

Vetor de ataque:

Um deep link manipulado pode alterar campos da reserva, inclusive `usuarioId`, causando bypass de autorização ou crash da aplicação.

Recomendação:

Nunca enviar objeto completo pela URL. Passar apenas `reservaId`, buscar a reserva no servidor e validar a resposta com Zod/Yup antes de renderizar.

Prazo sugerido: Imediato — até 3 dias

Responsável: Mobile / Backend

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M4-002

Categoria OWASP: M4 — Insufficient Input/Output Validation

Severidade: Alta

CWE: CWE-20 / CWE-1284

Componente afetado: `login.tsx`, `cadastro.tsx`, `lista.tsx`, `detalhar.tsx`, `api.ts`

Causa raiz:

Os formulários validam apenas campos vazios. Não há validação robusta de e-mail, senha, telefone, data, hora, observação ou tamanho máximo. Também não há validação server-side.

Evidência:

`handleCadastro()` verifica apenas `if (!nome || !email || !senha)`.
`fetchJson<T>()` faz cast cego da resposta da API.

Impacto CIA:

C: ☐ Alto ☒ Médio ☐ Baixo

I: ☒ Alto ☐ Médio ☐ Baixo

A: ☐ Alto ☒ Médio ☐ Baixo

Vetor de ataque:

Entradas inválidas ou malformadas podem ser gravadas no banco, causar inconsistência de dados, spoofing de conteúdo ou falhas de renderização.

Recomendação:

Criar schemas com Zod/Yup para login, cadastro, reserva e participante. Validar no cliente e no servidor. Substituir `fetchJson<T>` por `fetchValidated(schema, path)`.

Prazo sugerido: Curto prazo — até 1 semana

Responsável: Mobile / Backend

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M5-001

Categoria OWASP: M5 — Insecure Communication

Severidade: Crítica

CWE: CWE-319 / CWE-326

Componente afetado: `src/apiService/api.ts`

Causa raiz:

Todos os endpoints usam HTTP sem TLS. A URL base está hardcoded como `http://localhost:3000` ou `http://10.0.2.2:3000`.

Evidência:

`BASE_URL` definido com `http://` para web, Android e iOS.

Impacto CIA:

C: ☒ Alto ☐ Médio ☐ Baixo

I: ☒ Alto ☐ Médio ☐ Baixo

A: ☐ Alto ☒ Médio ☐ Baixo

Vetor de ataque:

Em rede Wi-Fi pública ou rede comprometida, um atacante pode interceptar ou modificar credenciais, dados de reserva e dados pessoais trafegando em texto claro.

Recomendação:

Usar HTTPS obrigatório em produção, variável `EXPO_PUBLIC_API_URL`, rejeitar `http://` em build de produção e configurar TLS 1.2+ ou TLS 1.3.

Prazo sugerido: Imediato — até 2 dias

Responsável: Backend / DevOps / Mobile

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M5-002

Categoria OWASP: M5 — Insecure Communication

Severidade: Alta

CWE: CWE-295

Componente afetado: Android/iOS network config

Causa raiz:

Não há certificate pinning, Network Security Config restritiva no Android ou ATS explícita no iOS. O app aceita certificados válidos de qualquer autoridade confiável do sistema.

Evidência:

Ausência de `react-native-ssl-pinning`, `react-native-pinch`, configuração OkHttp, `network_security_config.xml` e `NSAppTransportSecurity` restritiva.

Impacto CIA:

C: ☒ Alto ☐ Médio ☐ Baixo

I: ☒ Alto ☐ Médio ☐ Baixo
A: ☐ Alto ☒ Médio ☐ Baixo

Vetor de ataque:

Um proxy com certificado instalado no dispositivo ou uma CA comprometida pode interceptar tráfego HTTPS caso o app migre para HTTPS sem pinning.

Recomendação:

Configurar certificate pinning por domínio da API, `usesCleartextTraffic=false` no Android e `NSAllowsArbitraryLoads=false` no iOS.

Prazo sugerido: Curto prazo — até 1 semana

Responsável: Mobile / DevOps

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M6-001

Categoria OWASP: M6 — Inadequate Privacy Controls

Severidade: Alta

CWE: CWE-359

Componente afetado: `cadastro.tsx`, `detalhar.tsx`, fluxo geral do app

Causa raiz:

O app coleta nome, e-mail, senha, telefone, observação, dados de reserva e dados financeiros sem mecanismo de consentimento, política de privacidade, finalidade clara ou revogação.

Evidência:

Cadastro e inclusão de participantes não apresentam aceite de termos, política de privacidade ou controle de consentimento.

Impacto CIA:

C: ☒ Alto ☐ Médio ☐ Baixo

I: ☐ Alto ☒ Médio ☐ Baixo

A: ☐ Alto ☐ Médio ☒ Baixo

Vetor de ataque:

Tratamento indevido de dados pessoais pode gerar exposição de PII e não conformidade com LGPD, especialmente Art. 6, Art. 7, Art. 8, Art. 9 e Art. 18.

Recomendação:

Implementar tela de consentimento, política de privacidade, central de privacidade, exportação de dados, exclusão de conta, revogação de consentimento e política de retenção.

Prazo sugerido: Curto prazo — até 2 semanas

Responsável: Produto / Jurídico / Mobile / Backend

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M6-002

Categoria OWASP: M6 — Inadequate Privacy Controls

Severidade: Média

CWE: CWE-532 / CWE-359

Componente afetado: `login.tsx`, `cadastro.tsx`, `lista.tsx`, `detalhar.tsx`

Causa raiz:

Há múltiplas ocorrências de `console.log(error)` sem sanitização. Erros podem conter e-mail, senha, telefone, payloads de API e dados financeiros.

Evidência:

Foram identificadas aproximadamente 12 ocorrências de logs sem guarda `__DEV__` ou redaction.

Impacto CIA:

C: ☒ Alto ☐ Médio ☐ Baixo

I: ☐ Alto ☐ Médio ☒ Baixo

A: ☐ Alto ☐ Médio ☒ Baixo

Vetor de ataque:

Logs podem ser acessados por ferramentas de debug, ADB, Xcode ou serviços futuros de crash report, expondo dados pessoais.

Recomendação:

Criar logger centralizado com sanitização de campos sensíveis e remover logs em produção via configuração do Metro.

Prazo sugerido: Curto prazo — até 1 semana

Responsável: Mobile

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M7-001

Categoria OWASP: M7 — Insufficient Binary Protections

Severidade: Alta

CWE: CWE-693 / CWE-489

Componente afetado: build mobile, `app.json`, ausência de `eas.json`, bundle JS

Causa raiz:

Não há perfil de produção configurado com `eas.json`, obfuscação JS, anti-tampering, detecção de root/jailbreak, detecção de emulador ou bloqueio de depurador.

Evidência:

Ausência de `eas.json`, ausência de bibliotecas como `react-native-jailmonkey`, ausência de configuração de obfuscação e ausência de verificação de integridade do bundle.

Impacto CIA:

C: ☒ Alto ☐ Médio ☐ Baixo

I: ☒ Alto ☐ Médio ☐ Baixo
A: ☐ Alto ☒ Médio ☐ Baixo

Vetor de ataque:

Um atacante pode extrair o APK/IPA, analisar o bundle, recuperar endpoints, lógica de autenticação e manipular o app em ambiente rootado, emulador ou depurador.

Recomendação:

Criar `eas.json` com perfil production, habilitar build release, remover logs, usar Hermes, obfuscação JS, code signing do Expo Updates, detecção de root/emulador/debug e anti-tampering.

Prazo sugerido: Médio prazo — até 2 semanas

Responsável: Mobile / DevOps

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M8-001

Categoria OWASP: M8 — Security Misconfiguration

Severidade: Crítica

CWE: CWE-942 / CWE-307 / CWE-312

Componente afetado: backend `json-server`, `.gitignore`, configurações de API

Causa raiz:

O backend atual expõe CRUD sem autenticação, CORS permissivo, ausência de rate limiting, rota raiz com discovery de dados e banco `db.json` com PII no repositório.

Evidência:

`json-server` responde com `Access-Control-Allow-Origin: *`.

`.gitignore` não ignora `json-server/db.json`.

Não há rate limiting em `/usuarios`, `/reservas`, `/participantes` ou `/solicitacoes`.

Impacto CIA:

C: ☒ Alto ☐ Médio ☐ Baixo

I: ☒ Alto ☐ Médio ☐ Baixo

A: ☒ Alto ☐ Médio ☐ Baixo

Vetor de ataque:

Qualquer origem web pode consultar a API; endpoints podem ser abusados para enumeração, brute force, alteração ou exclusão de dados.

Recomendação:

Substituir `json-server` por API real com autenticação, CORS restrito, rate limiting, headers de segurança, validação de autorização e remoção de `db.json` do Git.

Prazo sugerido: Imediato — até 1 semana

Responsável: Backend / DevOps

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M8-002

Categoria OWASP: M8 — Security Misconfiguration

Severidade: Alta

CWE: CWE-489 / CWE-312

Componente afetado: `app.json`, `AndroidManifest/Info.plist` gerados

Causa raiz:

Configurações sensíveis não estão explicitamente protegidas: `allowBackup`, `debuggable`, `usesCleartextTraffic`, ATS iOS, source maps e OTA Updates com assinatura.

Evidência:

`app.json` não define `allowBackup=false`, não configura ATS, não possui `updates` com code signing e não há `metro.config.js` restritivo.

Impacto CIA:

C: ☒ Alto ☐ Médio ☐ Baixo

I: ☒ Alto ☐ Médio ☐ Baixo

A: ☐ Alto ☒ Médio ☐ Baixo

Vetor de ataque:

Backups locais, builds debug, source maps e updates sem assinatura podem expor dados, código-fonte e permitir manipulação de bundle.

Recomendação:

Definir `allowBackup=false`, `usesCleartextTraffic=false`, ATS restritiva, `runtimeVersion`, OTA code signing, `drop_console`, source maps controlados e pipeline CI/CD.

Prazo sugerido: Curto prazo — até 2 semanas

Responsável: Mobile / DevOps

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M9-001

Categoria OWASP: M9 — Insecure Data Storage

Severidade: Crítica

CWE: CWE-922 / CWE-312

Componente afetado: navegação, estado React, `db.json`, ausência de SecureStore

Causa raiz:

Dados sensíveis são mantidos em parâmetros de URL, estado React e arquivo `db.json`. Não há uso de `expo-secure-store`, Keychain, Keystore ou armazenamento criptografado.

Evidência:

`usuarioId`, `usuarioNome` e objeto completo de reserva trafegam nos parâmetros de rota. `expo-secure-store` não está instalado.

Impacto CIA:

C: ☒ Alto ☐ Médio ☐ Baixo

I: ☒ Alto ☐ Médio ☐ Baixo

A: ☐ Alto ☒ Médio ☐ Baixo

Vetor de ataque:

Dados de sessão e reserva podem ser recuperados por histórico de navegação, dumps de estado, backups locais, logs ou análise de dispositivo comprometido.

Recomendação:

Instalar `expo-secure-store`, armazenar token/sessão no Keychain/Keystore, limpar dados no logout, evitar dados sensíveis em URL, adicionar `Cache-Control: no-store` e proteger telas sensíveis contra screenshots.

Prazo sugerido: Imediato — até 1 semana

Responsável: Mobile

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M9-002

Categoria OWASP: M9 — Insecure Data Storage

Severidade: Alta

CWE: CWE-200 / CWE-524 / CWE-532

Componente afetado: HTTP cache, logs, screenshots, Recent Apps

Causa raiz:

Não há controle de cache HTTP, proteção contra screenshots, blur em background ou tratamento seguro dos previews do sistema operacional.

Evidência:

`fetchJson()` não envia `Cache-Control: no-store`.

Não há `FLAG_SECURE`, `BlurView` em background ou plugin equivalente.

Impacto CIA:

C: ☒ Alto ☐ Médio ☐ Baixo

I: ☐ Alto ☐ Médio ☒ Baixo

A: ☐ Alto ☐ Médio ☒ Baixo

Vetor de ataque:

Dados pessoais e financeiros podem aparecer em cache local, logs, prints, multitasking snapshots e tela de recentes.

Recomendação:

Adicionar headers `Cache-Control: no-store`, remover logs em produção, proteger telas sensíveis e aplicar blur quando o app for para background.

Prazo sugerido: Curto prazo — até 2 semanas

Responsável: Mobile

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M10-001

Categoria OWASP: M10 — Insufficient Cryptography

Severidade: Crítica

CWE: CWE-327 / CWE-326 / CWE-330

Componente afetado: autenticação, sessão, transporte, armazenamento

Causa raiz:

A aplicação praticamente não utiliza criptografia onde deveria: não há hash de senha, JWT assinado, TLS em produção, SecureStore, HMAC, gerenciamento de chaves ou geração segura de tokens.

Evidência:

Busca por `crypto`, `hash`, `bcrypt`, `argon2`, `jwt`, `encrypt`, `decrypt` em `src/` não encontrou implementação criptográfica relevante.

Impacto CIA:

C: ☒ Alto ☐ Médio ☐ Baixo

I: ☒ Alto ☐ Médio ☐ Baixo

A: ☒ Alto ☐ Médio ☐ Baixo

Vetor de ataque:

Sem criptografia adequada, credenciais, identidade do usuário, dados em trânsito e dados em repouso podem ser lidos, alterados ou forjados.

Recomendação:

Implementar Argon2id/bcrypt para senhas, JWT com RS256/ES256, TLS 1.3, SecureStore, geração segura com `crypto.getRandomValues` ou `expo-crypto`, rotação de chaves e auditoria criptográfica contínua.

Prazo sugerido: Imediato — até 1 semana

Responsável: Backend / Mobile / DevOps

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-GERAL-001

Categoria OWASP: M1/M3/M5/M8/M9/M10 — Falha sistêmica de arquitetura de segurança

Severidade: Crítica

CWE: CWE-306 / CWE-319 / CWE-522 / CWE-922

Componente afetado: arquitetura geral do app e backend

Causa raiz:

O projeto usa `json-server` como backend funcional, sem autenticação, sem autorização, sem criptografia, sem validação server-side e sem controles de privacidade.

Evidência:

Todos os módulos auditados apontam para a mesma causa raiz: inexistência de backend seguro e excesso de decisões de segurança feitas no cliente.

Impacto CIA:

C: ☒ Alto ☐ Médio ☐ Baixo

I: ☒ Alto ☐ Médio ☐ Baixo

A: ☒ Alto ☐ Médio ☐ Baixo

Vetor de ataque:

Um atacante pode acessar endpoints, obter usuários, manipular reservas, interceptar tráfego, alterar identidade por URL e explorar dados armazenados de forma insegura.

Recomendação:

Priorizar uma refatoração arquitetural: backend real, autenticação server-side, autorização por token, HTTPS, banco seguro, validação server-side, logs sanitizados e pipeline de segurança.

Prazo sugerido: Imediato — iniciar antes de qualquer deploy real

Responsável: Tech Lead / Backend / Mobile / DevOps

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M2-003

Categoria OWASP: M2 — Inadequate Supply Chain Security

Severidade: Média

CWE: CWE-829

Componente afetado: dependências transitivas e scripts de instalação

Causa raiz:

Há scripts de lifecycle em dependências, incluindo `postinstall` de binário nativo, e grande superfície de dependências transitivas.

Evidência:

`unrs-resolver` executa `postinstall`. O lockfile possui aproximadamente 998 pacotes.

Impacto CIA:

C: ☐ Alto ☒ Médio ☐ Baixo

I: ☐ Alto ☒ Médio ☐ Baixo

A: ☐ Alto ☒ Médio ☐ Baixo

Vetor de ataque:

Comprometimento de pacote npm ou script de instalação pode executar código no ambiente do desenvolvedor ou CI/CD.

Recomendação:

Auditar scripts de lifecycle, usar `npm ci`, habilitar Dependabot/Renovate, executar `npm audit` no CI e reduzir dependências desnecessárias.

Prazo sugerido: Médio prazo — até 2 semanas

Responsável: DevOps

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M4-003

Categoria OWASP: M4 — Insufficient Input/Output Validation

Severidade: Média

CWE: CWE-1284

Componente afetado: política de senha, campos de data/hora, resposta da API

Causa raiz:

A política de senha é apenas visual e não bloqueia senhas fracas. Campos de data/hora podem receber valores inválidos no modo web. Respostas da API são aceitas sem validação runtime.

Evidência:

`calcStrength()` calcula força, mas `handleCadastro()` não impede cadastro com senha fraca.
`converterHoraParaMinutos()` não valida formato antes de converter.

Impacto CIA:

C: ☐ Alto ☒ Médio ☐ Baixo

I: ☐ Alto ☒ Médio ☐ Baixo

A: ☐ Alto ☒ Médio ☐ Baixo

Vetor de ataque:

Usuários podem cadastrar senhas fracas e registros inconsistentes, aumentando risco de brute force, falhas de lógica e indisponibilidade parcial.

Recomendação:

Aplicar validação obrigatória de senha, data e hora no cliente e no servidor. Rejeitar entradas inválidas antes de persistir.

Prazo sugerido: Curto prazo — até 1 semana

Responsável: Mobile / Backend

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M5-003

Categoria OWASP: M5 — Insecure Communication

Severidade: Média

CWE: CWE-693

Componente afetado: headers HTTP e modo web

Causa raiz:

O backend atual não aplica cabeçalhos de segurança como HSTS, CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy e Permissions-Policy.

Evidência:

`json-server` responde sem headers de hardening e com CORS aberto.

Impacto CIA:

C: ☐ Alto ☒ Médio ☐ Baixo

I: ☐ Alto ☒ Médio ☐ Baixo

A: ☐ Alto ☐ Médio ☒ Baixo

Vetor de ataque:

No modo web, ausência de headers aumenta exposição a ataques de navegação, embedding indevido, MIME sniffing e vazamento de referência.

Recomendação:

Adicionar `helmet` no backend real e configurar HSTS, CSP restritiva, X-Frame-Options, X-Content-Type-Options e CORS restrito.

Prazo sugerido: Médio prazo — até 2 semanas

Responsável: Backend / DevOps

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M7-002

Categoria OWASP: M7 — Insufficient Binary Protections

Severidade: Média

CWE: CWE-540

Componente afetado: Metro bundler, source maps, ProGuard/R8

Causa raiz:

Não há configuração explícita para source maps, minificação avançada, ProGuard/R8 customizado ou remoção de símbolos em produção.

Evidência:

Ausência de `metro.config.js`, ausência de regras ProGuard customizadas e ausência de perfil EAS de produção.

Impacto CIA:

C: ☐ Alto ☒ Médio ☐ Baixo

I: ☐ Alto ☒ Médio ☐ Baixo

A: ☐ Alto ☐ Médio ☒ Baixo

Vetor de ataque:

Source maps ou bundle pouco protegido facilitam engenharia reversa, extração de endpoints, regras de negócio e lógica de autorização.

Recomendação:

Configurar Metro para produção, remover console/debugger, proteger source maps, usar R8/ProGuard e restringir acesso a artefatos de build.

Prazo sugerido: Médio prazo — até 2 semanas

Responsável: Mobile / DevOps

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

ID: VULN-M2-004

Categoria OWASP: M2 — Inadequate Supply Chain Security

Severidade: Baixa

CWE: CWE-1104

Componente afetado: dependências transitivas deprecated

Causa raiz:

O projeto possui dependências transitivas antigas ou deprecated, como `inflight`, `rimraf` antigo e versões antigas de `glob`.

Evidência:

Auditoria identificou pacotes deprecated e não recomendados para uso contínuo.

Impacto CIA:

C: ☐ Alto ☐ Médio ☒ Baixo

I: ☐ Alto ☐ Médio ☒ Baixo

A: ☐ Alto ☒ Médio ☐ Baixo

Vetor de ataque:

Pacotes não mantidos podem conter bugs, vazamentos de memória ou vulnerabilidades futuras sem correção.

Recomendação:

Monitorar dependências, aplicar overrides com cautela, atualizar pacotes intermediários e manter auditoria contínua no CI.

Prazo sugerido: Backlog técnico — até 30 dias

Responsável: DevOps / Mobile

Status: ☒ Pendente ☐ Em andamento ☐ Corrigido ☐ Aceito

PLANO DE REMEDIAÇÃO

Prioridade 1 — Imediato (Críticos)

1. Substituir autenticação client-side por `POST /auth/login` no backend.
2. Remover senhas plaintext e aplicar Argon2id ou bcrypt.
3. Remover `usuarioId` e dados de sessão dos parâmetros de URL.
4. Implementar JWT ou token de sessão com validação server-side.
5. Substituir HTTP por HTTPS obrigatório em produção.
6. Remover `db.json` do repositório e limpar histórico Git, se necessário.

7. Substituir `json-server` por backend real com autenticação, autorização, CORS restrito e rate limiting.
 8. Corrigir vulnerabilidades críticas de dependências com `npm audit fix`.
-

Prioridade 2 — Curto prazo (Altos)

1. Implementar `expo-secure-store` para tokens e sessão.
 2. Criar `AuthContext` e proteger rotas no Expo Router.
 3. Implementar validação com Zod/Yup em formulários e respostas de API.
 4. Adicionar certificate pinning, `usesCleartextTraffic=false` e ATS restritiva.
 5. Criar tela de consentimento, política de privacidade e central LGPD.
 6. Criar `eas.json` com perfil production e OTA updates com code signing.
 7. Mover `json-server` para `devDependencies` e pinar versões críticas.
 8. Configurar CI/CD com `npm audit`, Semgrep, secret scanning e testes de segurança.
-

Prioridade 3 — Médio prazo (Médios)

1. Sanitizar logs e remover `console.log` em produção.
 2. Adicionar headers de segurança com `helmet`.
 3. Configurar Metro, source maps e ProGuard/R8.
 4. Proteger telas sensíveis contra screenshots e snapshots.
 5. Adicionar política de retenção e anonimização de dados.
 6. Monitorar dependências deprecated e transitivas.
 7. Implementar HMAC/nonce para integridade adicional em requisições sensíveis, se necessário.
-

Re-auditoria agendada para: Após conclusão da Prioridade 1 e Prioridade 2, preferencialmente em até 30 dias.

Conclusão:

O projeto, no estado atual, não deve ser utilizado em produção com dados reais. A maior parte dos riscos decorre do uso de `json-server` como backend funcional, autenticação no cliente, ausência de criptografia, ausência de TLS, exposição de dados pessoais e falta de controles de sessão. A correção deve começar pela arquitetura de autenticação e comunicação segura, seguida por validação, privacidade, hardening mobile e automação de segurança no CI/CD.